

Engineering Review — SentinelForge

What worked well

The strongest architectural decision was an explicit event contract between independent stages. It makes every transformation inspectable and allows the full pipeline to run without paid services or API keys. The offline intelligence fallback and append-only evidence files are especially useful during a live assessment because they eliminate network fragility while preserving the real integration boundary. The combined ML confidence policy is also more defensible than relying on a single score: behavioral anomaly, supervised probability, and external intelligence reinforce one another.

What I would change

For production, JSONL would be replaced by a transactional event store and queue. Case updates would use optimistic concurrency and a full analyst API. Model lifecycle management would include signed artifacts, drift monitoring, feature lineage, and champion/challenger evaluation. The current response actions are deliberately simulated; actual host isolation would require a tightly scoped EDR integration with approval gates.

Performance

On a typical laptop, the demo processes the included eight-event dataset in well under one second after model artifacts are present. The most variable component is external TI latency, which is bounded by the configured timeout and mitigated by caching. The stream simulator demonstrates near-real-time event flow while maintaining deterministic behavior.

10x scalability

At ten times the volume, I would use Kafka partitions by source, horizontally scaled workers, Redis for shared TI caching, PostgreSQL/TimescaleDB for indexed time windows, and a separate model-serving process. Dashboard queries would read pre-aggregated KPI tables rather than scanning raw evidence files.

Security risks and mitigations

Potential risks include malicious log injection, provider credential exposure, model poisoning, alert flooding, and unsafe automated response. Mitigations include schema validation,

environment-only secrets, signed training data and artifacts, per-source rate limiting, confidence thresholds, analyst approval, immutable audit logs, and an explicit non-destructive demo mode. The current implementation documents these limitations rather than hiding them.